

Architecture AD, Modèle en Tiers et LAPS

Objectifs :

- Comprendre et appliquer le modèle de cloisonnement en Tiers de l'ANSSI.
- Maîtriser l'application sécurisée des Stratégies de Groupe (GPO) et le filtrage WMI.
- Comprendre la vulnérabilité du processus LSASS et les attaques par mouvements latéraux (Pass-the-Hash).
- Déployer une gestion sécurisée des identités locales via Windows LAPS.

1. L'Architecture Sécurisée : Le Modèle en Tiers (Tiering)

Dans une infrastructure Active Directory non cloisonnée, la compromission d'un poste de travail bureautique conduit statistiquement à la compromission totale du domaine (Contrôleurs de Domaine) en moins de 48 heures. Pour briser ce cycle, l'ANSSI et Microsoft imposent le **Modèle en Tiers** (Tiering Model).

1.1 Définition des Tiers (Niveaux de confiance)

Le système d'information est découpé en zones de confiance étanches :

- **Tier 0 (Le cœur de confiance)** : Les Contrôleurs de Domaine (AD), les serveurs PKI (Certificats), les serveurs de fédération (ADFS), et les serveurs de sauvegarde. Une compromission du Tier 0 signifie la perte totale du SI.
- **Tier 1 (Les serveurs d'infrastructure)** : Les serveurs de fichiers, les bases de données (SQL), les serveurs applicatifs métiers, et la messagerie (Exchange).
- **Tier 2 (Les postes utilisateurs)** : Les PC bureautiques, les ordinateurs portables, les VDI, et les smartphones. C'est la zone la plus exposée aux ransomwares et au Phishing.

1.2 La règle de l'étanchéité

Le modèle en Tiers repose sur une restriction stricte des ouvertures de session : **Un compte d'administration d'un Tier supérieur ne doit JAMAIS ouvrir de session sur un Tier inférieur.**

- Scénario classique (Faille) : Un technicien utilise son compte "Admin du Domaine" (Tier 0) pour dépanner le PC de la comptabilité (Tier 2).
- Conséquence : Son mot de passe (Hash) reste en mémoire sur le PC. Si le PC est compromis, le pirate vole le Hash Tier 0 et prend le contrôle du domaine.
- Solution : L'administrateur doit posséder trois comptes distincts : **jdupont** (Bureautique

T2), *adm-T1-jdupont* (Gestion des serveurs T1), et *adm-T0-jdupont* (Gestion de l'AD T0). Des GPO interdisent techniquement (Deny Logon) le croisement de ces comptes.

2. L'Hygiène de l'Active Directory et des GPO

Les Group Policy Objects (GPO) sont l'arme de durcissement massive de l'administrateur Windows. Leur mauvaise application peut créer des brèches silencieuses.

2.1 Le principe du LSDOU (Ordre de traitement)

Les stratégies s'appliquent dans un ordre précis. La dernière appliquée écrase les précédentes :

1. **Locale** (secpol.msc sur la machine)
2. **Site** (Site physique AD)
3. **Domaine** (À la racine, ex: Default Domain Policy)
4. **OU** (Unité d'Organisation)

2.2 Règles de sécurité des GPO (Recommandations ANSSI)

- **Sanctuariser les politiques par défaut** : On ne modifie **jamais** la *Default Domain Policy* ou la *Default Domain Controllers Policy* pour y ajouter des réglages personnalisés (Pare-feu, AppLocker, etc.). On crée toujours des GPO dédiées, liées aux OU spécifiques.
- **Le Filtrage WMI (WMI Filtering)** : Plutôt que de cibler des GPO par groupes de sécurité (complexe à maintenir), utilisez des requêtes WMI pour cibler l'OS matériellement.
 - Exemple (Cibler uniquement Windows Server 2022) : `SELECT * FROM Win32_OperatingSystem WHERE Caption LIKE "%Windows Server 2022%"`
- **Délégation stricte** : Seuls les administrateurs du Tier 0 (Admin du domaine) doivent avoir le droit de lier ou de modifier une GPO (Droit de Link).

3. Mouvements Latéraux et Faille LSASS

Le principal vecteur de propagation d'une cyberattaque (Ransomware) sur un parc Windows s'appelle le **Mouvement Latéral**, rendu possible par le vol d'identifiants en mémoire.

3.1 Le processus LSASS (*lsass.exe*)

Le Local Security Authority Subsystem Service gère l'authentification sous Windows. Lorsqu'un utilisateur se connecte, LSASS stocke son mot de passe sous forme d'empreinte

cryptographique (Hash NTLM) ou de ticket (Kerberos) dans la mémoire vive (RAM) pour permettre le "Single Sign-On" (SSO).

3.2 L'attaque "Pass-the-Hash" (PtH)

Un attaquant disposant des droits "Administrateur Local" sur une machine peut utiliser des outils comme **Mimikatz** ou **ProcDump** pour lire la mémoire du processus LSASS.

1. Il extrait le Hash NTLM d'un administrateur venu se connecter récemment.
2. Le protocole NTLM ne nécessitant pas le mot de passe en clair, l'attaquant réutilise ("Passe") le Hash volé pour s'authentifier directement sur d'autres serveurs du réseau.

4. Sécurisation de l'Identité Locale : Windows LAPS

Le Pass-the-Hash est dévastateur si le mot de passe du compte Administrateur local (SID 500) est identique sur tout le parc informatique (ce qui est souvent le cas suite au déploiement via une image "Master").

4.1 La solution : LAPS (Local Administrator Password Solution)

LAPS est la réponse officielle de Microsoft. Il casse la possibilité de faire des mouvements latéraux via les comptes locaux.

- **Génération unique** : Le PC génère lui-même un mot de passe aléatoire très complexe (ex: 20 caractères alphanumériques et symboles).
- **Stockage dans l'AD** : Le mot de passe est transmis de manière chiffrée à l'Active Directory. Il est stocké dans un attribut spécifique de l'objet Ordinateur.
- **Rotation automatique** : Le mot de passe change automatiquement tous les X jours, ou immédiatement après avoir été consulté/utilisé par un technicien.

4.2 LAPS "Legacy" vs LAPS "Natif" (Windows LAPS)

- **Ancien LAPS** : Nécessitait l'installation d'un agent **.msi** sur chaque poste et la modification manuelle du schéma AD (Extension de schéma).
- **Windows LAPS (Moderne)** : Intégré nativement depuis Windows 11 (22H2) et Windows Server 2022, ou via les KB d'Avril 2023 pour les anciens OS. Les attributs AD sont protégés nativement par des mécanismes de chiffrement avancés, limitant la lecture aux seuls groupes autorisés.

Conséquence métier : Si un attaquant compromet un serveur et y vole le Hash de l'Administrateur local, ce Hash ne fonctionnera **nulle part ailleurs** sur le réseau.

